Internal purple team: from quiet network listening to compromised hybrid identity

An expert, authorization-first purple-team playbook that walks a single attack path end to end: quiet LLMNR/NBT-NS/mDNS listening with Responder, credential validation and lateral reconnaissance with NetExec, offline cracking with Hashcat, attack-path mapping with BloodHound CE, cloud directory enumeration with ROADtools and deep hybrid checks with AADInternals. It ends where it must: proving detection in Defender for Identity and Entra logs, then remediating the on-prem-to-cloud seams the path exploited. Defensive use only, on your own systems or with written permission.

9 phases | 25 steps | Tick each item when its "done when" criterion is true

Phase 1 Authorize the engagement, notify defenders and build the lab about 2–4 days

- [ ] **1.1 Get written authorization that names both on-prem AD and the Entra tenant**
  A signed or ticketed approval names the forest(s)/domains, the authorized VLAN(s) and subnets, the Entra tenant ID and primary domains, the date window, allowed techniques and a stop-contact
- [ ] **1.2 Notify the SOC and agree how engagement activity is marked**
  SOC has the window, the capture host IP/MAC and jump-host IPs, the test account UPNs/SamAccountNames, and the Entra app or account that will authenticate to Graph
- [ ] **1.3 Stand up a contained capture position and a cracking lab**
  A hardened Linux host on the authorized VLAN runs Responder; an isolated, offline lab holds any hashes that will be cracked; least-privilege accounts exist for enumeration

Phase 2 Quiet listening with Responder about 0.5–2 days

- [ ] **2.1 Baseline the broadcast domain in analyze mode first**
  Responder has run in analyze mode (`responder -I <iface> -A`) and you have a list of hosts emitting LLMNR/NBT-NS/mDNS without having answered a single query
- [ ] **2.2 Enable answering inside the authorized VLAN and capture NetNTLMv2**
  Responder is poisoning only in the authorized scope and NetNTLMv2 hashes are landing in its logs/ `Responder-Session.log` and hash files
- [ ] **2.3 Log the capture and set the cracking boundary**
  Every captured hash is recorded with account, source host and timestamp, and each is tagged lab/authorized-for-cracking or capture-only

Phase 3 Credential validation and lateral reconnaissance with NetExec about 1–2 days

- [ ] **3.1 Validate credentials across SMB/WinRM/LDAP in scope**
  You know, per in-scope host, whether a given credential authenticates over SMB (and where relevant WinRM/LDAP), and whether it holds local admin
- [ ] **3.2 Enumerate shares, sessions and directory objects**
  You have share/ACL, logged-on-session and relevant LDAP enumeration for the in-scope hosts, captured as files for the graph
- [ ] **3.3 Spray only if explicitly authorized, with lockout math first**
  Either no spraying occurred, or spraying followed the written clause with a documented attempts-per-window well under the domain lockout threshold

Phase 4 Offline cracking with Hashcat about 0.5–2 days

- [ ] **4.1 Crack NetNTLMv2 in mode 5600 against curated wordlists**
  Hashcat runs `-m 5600` against the authorized/lab hash file on the offline box and reports cracked/uncracked counts
- [ ] **4.2 Decide when to stop and what the result means**
  A written stop rule is honoured (coverage reached, time budget spent, or point proven) and results are expressed as weakness metrics, not a dump

Phase 5 Attack-path mapping with BloodHound CE about 1–3 days

- [ ] **5.1 Collect on-premises data with SharpHound and ingest it**
  A SharpHound collection is ingested into BloodHound CE and you can query from an owned principal to Tier 0 (Domain Admins / DC)
- [ ] **5.2 Collect the Entra tenant with AzureHound**
  An AzureHound collection for the in-scope tenant is ingested alongside the AD data in the same BloodHound CE instance
- [ ] **5.3 Analyse the hybrid edges from on-prem to tenant**
  You have at least one documented path that crosses the on-prem/Entra seam (synced account to Entra role, Entra Connect/sync service identity, or an on-prem admin with cloud privilege)

Phase 6 Cloud directory enumeration with ROADtools about 0.5–1 day

- [ ] **6.1 Authenticate and gather with ROADrecon**
  `roadrecon auth` succeeded for the assessment identity and `roadrecon gather` has populated `roadrecon.db`
- [ ] **6.2 Explore roles, apps and sync in the offline GUI**
  Notes exist on privileged role holders, risky app/service-principal permissions and consent grants, and the sync/Connect configuration, cross-checked against the BloodHound graph

Phase 7 Deep hybrid checks with AADInternals (read-first) about 0.5–1 day

- [ ] **7.1 Install AADInternals and obtain a cached token**
  Modules imported and a read token cached for the assessment identity (for example `Get-AADIntAccessTokenForAADGraph -SaveToCache`)
- [ ] **7.2 Read the hybrid posture: federation, PTA/PHS, Seamless SSO and sync**
  Notes exist on the sign-in method (PHS/PTA/federation), Seamless SSO state, sync/service details and tenant/service-location info — gathered with read-only cmdlets and compared to docs

Phase 8 Prove detection: on-premises capture and cloud enumeration about 1–2 days

- [ ] **8.1 Confirm on-prem visibility of poisoning, NTLM and logon anomalies**
  Logs show the Responder-era name-resolution anomalies and the NetExec authentications: 4624/4625 on targets, 4776 on DCs, and NTLM auditing events where enabled
- [ ] **8.2 Validate Defender for Identity lateral-movement and relay detections**
  The SOC has a runbook entry for the MDI alerts this path should raise (Pass-the-Hash, NTLM relay, identity-theft and enumeration alerts), tied to the sensors and event collection
- [ ] **8.3 Confirm Entra sign-in and audit visibility for the cloud enumeration**
  Sign-in logs show the ROADrecon/AADInternals authentications with their Conditional Access results, and audit logs show any directory reads in scope; gaps are ticketed

Phase 9 Remediate the seam, retest and close the engagement about 1–3 weeks

- [ ] **9.1 Kill the capture surface: LLMNR/NBT-NS/mDNS, SMB signing and NTLM**
  LLMNR is disabled by GPO/Intune, NBT-NS and mDNS are addressed, SMB signing is required, and NTLM auditing (and, where feasible, restriction) is in place
- [ ] **9.2 Harden the identity plane: local admin, tiering and the hybrid seam**
  Windows LAPS randomises local admin passwords, local-admin and lateral reuse are constrained by tiering, and the Entra Connect/sync identities are treated as Tier 0
- [ ] **9.3 Fix the Conditional Access and privileged-access gaps the path exploited**
  CA closes the gaps the cloud enumeration found (phishing-resistant MFA for admins, risk and legacy-auth policies), PIM replaces standing roles, and every change keeps a break-glass exclusion
- [ ] **9.4 Retest the path, wipe the loot and schedule the next window**
  The headline attack path no longer completes in a dated retest, every capture/hash/token/db is wiped or vaulted, and the next purple-team window is booked

Owner	Change / ticket	Date completed

Original checklist by Tenant Recipes, an independent project not affiliated with Microsoft or any vendor. Every step, its actions, pitfalls and the official sources it was checked against are on https://tenantrecipes.com/guides/purple-team-hybrid-identity.html. Time estimates are our own planning figures. Confirm against the linked sources and test in a pilot before production.